INCIDENT RESPONSE & FORENSIC INVESTIGATION REPORT

Show-Control Workstation Supply Chain & DNS Exfiltration

Target Asset: Show-Control Workstation (fogline-showctl)

Incident Date: 2026-10-13

Primary Threat: NPM Supply Chain / Transitive Dropper

Recovered Token: **forensic{8568b8444a7ac5335005c821}**

1. Executive Summary

During the peak operating week at the haunted-attraction park, a routine software maintenance command (`npm install`) executed on the primary show-control workstation (`fogline-showctl`) triggered a high-severity security incident. An internal mirror package (`npm-mirror.blackmere.lan:4873`) served a compromised transitive dependency, leading to automated payload retrieval, persistent execution staging, and covert DNS-based data exfiltration.

Forensic reconstruction of disk artifacts, volatile process memory traces, and Network Interface Card (NIC) packet captures verified that sensitive environment configuration files were archived into an encrypted staging ZIP (`tmpF81F.tmp`) and exfiltrated over 67 DNS A-record queries. Full reverse engineering of the encryption pipeline enabled complete payload reconstruction and recovery of the primary compromise target: the Showvault Root Token.

CRITICAL INCIDENT VERDICT & RECOVERED ROOT TOKEN

- **Recovered Flag / Root Token:** **forensic{8568b8444a7ac5335005c821}**
- **Exfiltrated Source File:** fogline-showctl/.env (SHOWVAULT_ROOT_TOKEN)
- **Cryptographic Integrity Verification:** CRC32 (d07c375f) & HMAC verification passed; ZIP payload exactly matched 1,944 bytes MFT allocation record.

2. Full Attack Chain Timeline

The following chronological matrix details the end-to-end execution flow of the compromise on October 13, 2026 (UTC):

Time (UTC)	Stage	Forensic Evidence	Technical Event Description
18:02:11	Initial Execution	Sysmon EID 1, npm log	User mvale executes npm install inside fogline-showctl targeting internal mirror

			npm-mirror.blackmere.lan:4873.
18:02:14	Package Resolution	npm log, package.json	fetchling@3.9.2 pulls in pale-hash-utils@2.1.0 (transitive dependency with postinstall: node setup.js).
18:02:40	Dropper Invocation	Sysmon EID 1	postinstall script setup.js fires under Node.js process context.
18:02:42	Staging Payload Fetch	PCAP, Sysmon EID 3/22	setup.js downloads /static/fonts/inter-var.woff2 from cdn.ossuary-assets.com (203.0.113.77:80). File is encrypted payload.
18:02:43	Payload Decryption	Sysmon EID 1/11	setup.js decrypts blob to C:\ProgramData\wt\wt.ps1 (3,061 bytes) and executes via powershell -NoP -NonI -w hidden -ep bypass.
18:02:47	C2 Blocked (Proxy)	PCAP, Sysmon EID 3	Outbound HTTPS telemetry POST through Squid proxy is blocked by policy (Newly Observed Domain).
18:03:03-06	DNS Key Exchange	PCAP	Fallback C2: TXT query to gravelantern.net returns NXDOMAIN; TXT query to mothwick-cdn.com returns key disguised as DKIM record.
18:03:08	Data Archiving	Sysmon EID 11, MFT	Malware archives 6 sensitive host environment files into encrypted ZIP tmpF81F.tmp (1,944 bytes).
18:03:10-40	DNS Exfiltration	PCAP	Encrypted archive exfiltrated across 67 DNS A-queries alternating between mothwick-cdn.com & pallbearer-metrics.io.
18:05:42	Final Beacon	PCAP	Finalization beacon sent with total chunk count and payload CRC32 (d07c375f).

18:06:02	Anti-Forensic Clean	Sysmon EID 23, MFT	Malware deletes wt.ps1, tmpF81F.tmp, setup.js, and swaps package.md back to package.json to hide postinstall hook.

3. Forensic Technical Reconstruction

Stage 1: Transitive Dependency & Dropper Mechanics

Although the malware attempted disk wiping on `setup.js`, the uncompressed plaintext HTTP tarball (`pale-hash-utils-2.1.0.tgz`) was extracted from the PCAP stream. Its byte size (2,857 bytes) and SHA-256 hash matched the Sysmon file deletion log (EID 23). Analysis of `setup.js` string tables revealed an AES-256-CBC key derivation mechanism based on salt `a6e217fb8de38593` concatenated with 8 random digits derived from the target's `_ga` tracking cookie.

Stage 2: Payload Unpacking & In-Memory Logic (wt.ps1)

Decryption of `/static/fonts/inter-var.woff2` yielded the second-stage PowerShell file `C:\ProgramData\wt\wt.ps1` (SHA-256: `72cf4127...`), matching MFT record sizes (3,061 bytes). The payload container was Gzip-compressed and Base64-encoded. Decompressing this script uncovered the DNS tunneling logic and key exchange protocol.

Stage 3: Key Exchange & Custom Base32 DNS Tunneling

The stage-3 script executed the following cryptographic and tunneling protocol:

- **System Identification & Key Query:** Computed MD5 hash of MachineGuid (bed3068c-ea38-419c-b94e-ab6d20d90816). Formed DNS query label cfg-bed3068c.
- **Key Retrieval via DKIM TXT:** Extracted Base64 TXT value from mothwick-cdn.com. Defined Key K = First 16 bytes. Derived Session ID = sha256(K)[:8] = d28b8884.
- **Sequence XOR Obfuscation:** Each outbound DNS chunk sequence index was XORed with 0x8884 to evade sequential inspection.
- **Custom Base32 Encoding:** Chunks encoded using custom alphabet: f64zjcir35umnyosv2hkwqx7ablgetdp.
- **Archive Structure & Cryptography:** Target archive payload constructed as IV (16B) || Ciphertext || HMAC-SHA256[:16]. Key derived via sha256(K || MachineGuid).

4. Exfiltrated Secrets & Impact Assessment

Reassembly and decryption of `tmpF81F.tmp` confirmed that six critical system environment files were exfiltrated. The following credential stores have been marked as compromised and require immediate remediation:

Asset / Context	Exfiltrated Credential / Secret	Risk & Exposure Impact

Showvault Root Access	**SHOWVAULT_ROOT_TOKEN (forensic{8568b8444a7ac5335005c821})**	Full administrative takeover of central Showvault control server.
Database Systems	Postgres credentials (showctl@db01)	Direct SQL write/read access to production show control DB.
Lighting & FX Controls	DMX Gateway API Key & Access Token	Unauthorized manipulation of lighting, fog, and prop sequence triggers.
Operational Infrastructure	Fog-controller PIN, Ticketing Webhook & Session secrets	Operational disruption and ticketing validation bypass.
Software Mirror Registry	NPM Mirror Auth Token (npm-mirror.blackmere.lan)	Registry poisoning / secondary supply chain injection across internal networks.
Source Control & Host Access	GitHub PAT (.git-credentials), SSH Keys (db01, files)	Full repository write access and lateral movement to database & file servers.

5. Containment & Remediation Plan

1. Immediate Credential Revocation: Rotate SHOWVAULT_ROOT_TOKEN, Postgres DB passwords, DMX Gateway API keys, GitHub PAT, SSH keys, and internal npm mirror tokens across all environments.

2. NPM Registry Hardening: Remove pale-hash-utils@2.1.0 from internal mirror. Audit all internal hosts for fetchling@3.9.2. Enforce global ignore-scripts=true on show-control nodes.

3. Network Block & Sinkhole: Enforce perimeter firewall and DNS sinkhole rules for IoCs: 203.0.113.77, cdn.ossuary-assets.com, mothwick-cdn.com, pallbearer-metrics.io, and gravelantern.net.

4. SIEM Threat Detection Rules: Deploy alerts for high-entropy subdomains, DNS queries matching custom Base32 patterns, and unexpected TXT record lookups originating from internal workstations.

5. Host Re-imaging & Forensics: Re-image workstation fogline-showctl from clean baseline image. Enable PowerShell Script Block Logging (EID 4104) and Module Logging prior to redeployment.